SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE: ITA1410**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks**.(20 Mark).**

3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.**(10 Marks)**

Code of Conduct:

I **T. Dharani Devi (192425036)** *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: **Dharani Devi T**

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures.	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

QUESTION 1: OSINT-Based Email Enumeration Using theHarvester

1. Introduction

Open-Source Intelligence (OSINT) is the process of collecting information from publicly available sources. It is widely used in cybersecurity to understand an organization's online presence and identify possible security risks.

Email enumeration is an OSINT technique used to identify email addresses associated with a domain. Security professionals use this information to evaluate whether publicly exposed contact details could be misused.

TheHarvester is a reconnaissance tool available in Kali Linux. It can collect publicly available information, such as email addresses, subdomains, hostnames, and IP addresses, depending on the selected data source.

In this experiment, the domain tesla.com is used as the example target. The collected information must be limited to public sources and used only for authorized security analysis.

2. Aim

To perform passive OSINT reconnaissance on the domain tesla.com using theHarvester, examine publicly available email addresses and domain information, classify relevant email addresses where evidence supports classification, and recommend security measures to reduce the risks of phishing and impersonation.

3. Objectives

1. To understand the concept of OSINT and email enumeration.
2. To learn how to use theHarvester in Kali Linux.
3. To collect publicly available email addresses and domain-related information.
4. To identify publicly visible subdomains, hosts, and IP addresses where the data source provides them.
5. To classify email addresses into suitable organizational categories when reliable evidence is available.
6. To analyze risks such as spear-phishing, credential theft, and email impersonation.
7. To recommend countermeasures that improve organizational email security.

4. Tools and Requirements

Tool or resource	**Purpose**
Kali Linux	Operating system for the experiment
theHarvester	Public-information reconnaissance
Terminal	Running commands and viewing output
Public data sources	Providing publicly indexed information
Report document	Recording findings and recommendations

5. Theory

5.1 Open-Source Intelligence

OSINT collects information from sources that are publicly accessible, such as websites, search engines, public certificates, and public directories. It does not require breaking into systems or accessing private accounts.

Organizations use OSINT to identify exposed information, review their digital footprint, and improve their security policies.

5.2 Email Enumeration

Email enumeration is the identification of email addresses associated with a domain. Addresses may be published on official contact pages, press releases, job listings, or other public documents.

For example, a public website might display a general contact address. This does not mean that the address is vulnerable, but it may attract spam or impersonation attempts.

5.3 theHarvester

theHarvester is a reconnaissance tool designed to collect information from supported public sources. Its results depend on the software version, selected source, source availability, and the information indexed by that source.

The results should be treated as leads that require validation, not as a complete or guaranteed list of an organization's assets.

6. Procedure

Step 1: Open Kali Linux

Start Kali Linux and open the terminal. Confirm that the system is ready to run the tool.

Step 2: Check whether theHarvester is available

Run:

theHarvester -h

This displays the available options and helps confirm that the command is recognized.

Screenshot 1: Capture the help output.

Step 3: Check the tool version or installation

If the command is not recognized, check the installation instructions provided by the Kali Linux package documentation before installing it.

Step 4: Perform passive reconnaissance

Use a supported public source for a limited lookup:

theHarvester -d tesla.com -b crtsh

Here:

- -d specifies the domain.
- tesla.com is the example domain.
- -b crtsh selects the Certificate Transparency source, if supported by the installed version.

This source can help reveal publicly recorded certificate-related domain names. It may not return email addresses.

Screenshot 2: Capture the command and actual output.

Step 5: Save the results

If the installed version supports the relevant options, save the output to a report file:

theHarvester -d tesla.com -b crtsh -f tesla_osint

Check the help output first because supported output formats and options may differ between versions.

Screenshot 3: Capture the saved-output confirmation or resulting files.

Step 6: Record the findings

Copy the actual results into the report. Separate email addresses, subdomains, hostnames, and IP addresses into different categories.

Do not invent email addresses or report unverified information as a confirmed finding.

Step 7: Classify email addresses

Where public evidence supports the classification, organize addresses into categories such as:

- Support
- Sales
- Human Resources (HR)
- Administration
- Technical

If the role cannot be established reliably, mark it as Unknown / Unverified. An address alone may not reveal the person's department.

Step 8: Analyze the risks

Review how exposed contact information could be misused. Consider phishing, impersonation, spam, and attempts to obtain confidential information.

Step 9: Recommend countermeasures

Prepare security recommendations based on the findings and the level of exposure observed.

Step 10: Prepare the final report

Include the aim, objectives, tools, commands, screenshots, actual findings, risk analysis, countermeasures, and conclusion.

7. Findings Table

Fill this table using the output actually collected in Kali Linux.

Information type	**Actual finding**
Domain examined	tesla.com
Data source used	crt.sh, if supported
Email addresses	Enter verified results, or write “None returned”
Subdomains	Enter observed results
Hostnames	Enter observed results
IP addresses	Enter observed results, if returned
Tool limitations	Record unavailable sources, errors, or incomplete data

8. Classification of Email Addresses

Category	Example of a role-based pattern	Security concern
Support	support@domain	Fake customer-support messages
Sales	sales@domain	Fraudulent quotations or invoices
HR	careers@domain	Fake recruitment messages
Administration	admin@domain	Impersonation of administrative staff
Technical	it@domain	Fake IT-support requests

These are illustrative patterns only, not confirmed Tesla email addresses.

9. Risk Analysis

9.1 Spear-Phishing

Attackers may use publicly available information to make deceptive messages appear relevant to particular employees or departments. Such messages can encourage recipients to open an attachment, visit an untrusted website, or disclose confidential information.

9.2 Credential Harvesting

A fraudulent message may direct a user to a fake sign-in page. If the user enters a password, the information could be stolen.

Organizations can reduce this risk through multifactor authentication, phishing-resistant sign-in methods, email filtering, and user awareness training.

9.3 Email Impersonation

An attacker may pretend to be a genuine employee, support team, supplier, or manager. The attacker may then request confidential documents or unauthorized payments.

Domain authentication policies and independent verification of sensitive requests help reduce this risk.

9.4 Spam and Unwanted Communication

Publicly listed email addresses may receive bulk messages, fraudulent offers, or unsolicited attachments. Email filtering and reporting procedures can help reduce the impact.

9.5 Exposure of Organizational Structure

Public contact information may reveal general roles or departments. When combined with other public information, this can make deceptive communications more convincing.

9.6 Incomplete or Incorrect Data

OSINT results can contain outdated records, duplicate entries, and information unrelated to the current organization. Therefore, findings should be checked before they are used to make security decisions.

10. Countermeasures

1. Email authentication: Configure SPF, DKIM, and DMARC to help prevent unauthorized senders from impersonating the organization's domain.
2. Multifactor authentication: Require additional verification for accounts, especially those with administrative access.

3. Phishing awareness training: Teach employees to recognize suspicious messages, unexpected attachments, and unusual requests.
4. Secure email gateway: Filter spam, malicious links, and suspicious attachments before they reach users.
5. Limit unnecessary public exposure: Review public contact information and publish only what is needed for business purposes.
6. Verify sensitive requests: Confirm payment changes, password requests, and confidential-data requests through a separate trusted channel.
7. Monitor domain misuse: Review reports of fraudulent domains and impersonation attempts.
8. Incident reporting: Give employees a simple process for reporting suspicious emails to the security team.
9. Access control: Apply least-privilege permissions so that compromised accounts cannot access unnecessary resources.
10. Regular security audits: Periodically review public information and email security configurations.

11. Ethical and Legal Considerations

TheHarvester should be used only for legitimate security assessment and educational purposes. Collection should remain limited to publicly accessible sources and the approved scope of the exercise.

Do not attempt to access private accounts, bypass access controls, send deceptive messages to real employees, or use collected addresses for unsolicited communication. The findings should be handled responsibly and shared only with authorized people.

12. Result

The OSINT procedure demonstrates how theHarvester can be used in Kali Linux to examine publicly available domain-related information. The collected results can help an organization understand its public exposure and identify potential email-security risks. Actual findings must be documented from the tool output, and suitable countermeasures should be recommended.

QUESTION 2: Phishing Awareness Simulation Using GoPhish

1. Introduction

Phishing is a social-engineering technique in which a person receives a deceptive message designed to influence them to take an unsafe action. The message may imitate a trusted organization or colleague and encourage the recipient to open a link or attachment.

GoPhish is a platform used by security teams to conduct controlled phishing-awareness exercises. It can help organizations understand how employees respond to simulated messages and identify areas where security training should be improved.

A phishing simulation must be designed carefully. For this experiment, only dummy employee accounts and an isolated or explicitly authorized lab environment should be used. The exercise must not collect real passwords or expose participants to harmful content.

2. Aim

To conduct a controlled phishing-awareness simulation using GoPhish, measure email delivery and user interactions, analyze the results, and recommend measures to improve employee awareness and organizational email security.

3. Objectives

1. To understand the concept of phishing and social engineering.
2. To become familiar with the GoPhish platform.
3. To create a harmless awareness-training email.
4. To use dummy employee accounts in a controlled lab.
5. To record delivery, opening, and link-clicking statistics.
6. To evaluate the results and identify awareness-training needs.
7. To recommend technical and administrative security controls.

4. Tools and Requirements

Tool or resource	Purpose
Kali Linux or another approved lab system	Running the exercise
GoPhish	Managing the awareness simulation
Dummy employee accounts	Testing without involving real employees
Lab email environment	Delivering controlled test messages
Awareness landing page	Displaying training information
Spreadsheet or report	Recording and analyzing metrics

5. Theory

5.1 Phishing

Phishing uses deceptive messages to encourage recipients to perform actions that may compromise their security. Common warning signs include unexpected requests, unfamiliar links, suspicious attachments, unusual urgency, and requests for sensitive information.

5.2 Social Engineering

Social engineering exploits trust, curiosity, urgency, or authority. For example, a message may appear to come from a technical-support team or request an urgent account review.

5.3 GoPhish

GoPhish helps authorized security teams organize controlled simulations and record events. Depending on the configuration, it can report delivery events, email openings, link clicks, and other interactions.

Tracking is not always perfect. Email privacy features and automated scanners may affect recorded opens and clicks.

5.4 Importance of Awareness Training

Employees who understand phishing indicators are more likely to pause, verify unexpected requests, and report suspicious messages. Awareness training should be supportive and educational rather than punitive.

6. Procedure

Step 1: Prepare the lab

Use an isolated test environment or an explicitly authorized training environment. Create dummy accounts and ensure the exercise cannot send messages to unintended recipients.

Step 2: Open GoPhish

Start GoPhish according to the installation instructions for the lab environment. Access its administrative interface using the configured local address.

Keep the administrative interface restricted to the authorized operator.

Screenshot 1: Capture the GoPhish dashboard with sensitive details hidden.

Step 3: Create a dummy recipient group

Create a group containing test accounts controlled by the lab operator. Verify that the recipients are dummy accounts and not real employees.

Screenshot 2: Capture the test-recipient group.

Step 4: Create an awareness email template

Use a harmless message that clearly directs the test recipient to an approved awareness page.

Subject: Security Awareness Training — Sample Email

Hello,

This is a security-awareness exercise conducted in the approved training environment.

Please review the organization's guidance on identifying suspicious emails, verifying senders, and reporting unusual messages.

Never enter a real password or confidential information into an unverified page.

Thank you,

Security Awareness Team

This template is intended for a controlled awareness exercise. It should not imitate a real employee or collect credentials.

Screenshot 3: Capture the harmless training template.

Step 5: Prepare the awareness landing page

Configure the landing page to display educational information about phishing indicators and safe reporting procedures.

Do not include a real login form or collect actual passwords. If the lab records a click event, show a training message explaining the warning signs that users should check.

Screenshot 4: Capture the awareness page.

Step 6: Configure the campaign

Select the dummy recipient group, the approved training template, and the awareness landing page. Confirm that the delivery configuration is limited to the lab.

Step 7: Launch the simulation

Start the campaign only after verifying the recipients and the scope. Record the number of messages sent and the delivery status.

Screenshot 5: Capture the campaign summary, with account details hidden.

Step 8: Monitor interactions

Review the available campaign statistics, such as:

- Messages sent
- Messages delivered
- Messages opened
- Training links clicked
- Messages reported, if reporting is configured

Do not treat an open or click event as proof that a real person intentionally interacted with the message; automated systems may affect these measurements.

Step 9: Calculate the metrics

Use the following formulas:

$$\text{Delivery Rate}= \frac{\text{Delivered}}{\text{Sent}}\times100$$

$$\text{Open Rate}= \frac{\text{Opened}}{\text{Delivered}}\times100$$

$$\text{Click Rate}= \frac{\text{Clicked}}{\text{Delivered}}\times100$$

Step 10: Analyze the results

Identify which training topics require improvement. For example, a high click rate in a controlled test may indicate that employees need more practice identifying suspicious links.

Step 11: Prepare the final report

Include screenshots, the campaign metrics, observations, recommendations, and the final result.

7. Sample Results and Calculations

The following numbers are illustrative only. Replace them with your actual GoPhish results.

Metric	**Example value**
Emails sent	20
Emails delivered	18
Emails opened	12
Training links clicked	4

Delivery rate

$$\frac{18}{20}\times100=90\%$$

Open rate

$$\frac{12}{18}\times100\approx66.7\%$$

Click rate

$$\frac{4}{18}\times100\approx22.2\%$$

These percentages demonstrate the calculations; they are not actual findings from a completed campaign.

8. Analysis of Results

8.1 Email Delivery

The delivery rate indicates how many sent messages reached the intended test accounts. A low rate may result from configuration problems, blocked messages, or incorrect recipient details.

8.2 Email Opens

The open rate gives an approximate indication of message visibility. It should be interpreted cautiously because email clients may block or automatically load tracking images.

8.3 Link Clicks

The click rate shows how often the training link was accessed according to the campaign data. A higher rate can indicate a need for additional awareness training, but the result should be considered alongside the limitations of automated scanning.

8.4 Reporting Behavior

If the exercise measures reporting, examine whether users identify and report the message. Reporting suspicious emails is an important positive security behavior.

8.5 Overall Interpretation

The campaign should not be judged using only one metric. A useful assessment combines delivery information, user interactions, reporting behavior, technical controls, and feedback from the training exercise.

9. Common Phishing Indicators

1. Unexpected requests for sensitive information.
2. Links that do not match the claimed destination.
3. Unusual urgency or pressure.
4. Unfamiliar senders or suspicious sender addresses.
5. Unexpected attachments.
6. Requests to bypass normal approval procedures.
7. Messages that discourage independent verification.

10. Recommendations to Improve Awareness

1. Regular training: Conduct short, periodic training sessions on phishing indicators.
2. Safe reporting process: Provide a clear method for reporting suspicious messages.
3. Email filtering: Use filtering tools to identify spam, malicious links, and unsafe attachments.
4. Multifactor authentication: Reduce the impact of stolen passwords by requiring additional verification.
5. Phishing-resistant authentication: Where available, adopt authentication methods that resist credential-phishing attacks.
6. Sender verification: Teach users to verify unexpected requests through a trusted communication channel.
7. Clear policies: Establish procedures for handling suspicious links, attachments, and requests for confidential information.

8. Supportive feedback: Use simulation results to teach employees rather than embarrass or punish them.
9. Incident response: Prepare a process for responding to suspected account compromise.
10. Repeat assessment: Conduct authorized follow-up exercises to evaluate whether training improves behavior.

11. Ethical Considerations

The exercise must be authorized and limited to dummy accounts or an approved participant group. Real passwords, confidential information, and unnecessary personal data must not be collected.

The organization should establish the purpose and scope of the exercise before launching it. Results should be stored securely and used to improve awareness and technical controls.

12. Result

A controlled GoPhish awareness simulation demonstrates how delivery and interaction metrics can be recorded and analyzed. The findings can help identify training needs and improve email security. The final report should use actual lab results and recommend suitable preventive measures.

QUESTION 3: Nmap Aggressive Scan and Social-Engineering Risk Analysis

1. Introduction

Network scanning is an important part of cybersecurity assessment. It helps administrators identify reachable systems, open ports, and services that may require security review.

Nmap, which stands for Network Mapper, is a network exploration and security auditing tool. It can identify hosts and ports and, when appropriate, help determine service versions and operating-system characteristics.

The -A option enables several advanced detection features. These may include operating-system detection, service/version detection, script scanning, and traceroute. The scan can generate more traffic and may be more intrusive than a basic port scan.

In this experiment, the results are used to understand how exposed technical information could increase social-engineering risks and how administrators can reduce those risks.

Important: Perform aggressive scans only against systems for which you have explicit permission and where the scan type is permitted. For this report, use a designated lab machine or another explicitly authorized target.

2. Aim

To study Nmap scanning, examine operating-system and service information from an authorized lab target, evaluate how exposed technical information may increase social-engineering risks, and recommend defensive security measures.

3. Objectives

1. To understand network reconnaissance and port scanning.
2. To become familiar with Nmap in Kali Linux.
3. To identify open ports and available services on an authorized target.
4. To understand the purpose of service-version and operating-system detection.
5. To analyze the security implications of exposed service information.

6. To understand the relationship between technical information exposure and social engineering.
7. To recommend security controls for reducing the risks identified.

4. Tools and Requirements

Tool or resource	Purpose
Kali Linux	Operating system for the lab
Nmap	Network discovery and scanning
Authorized lab target	System being assessed
Terminal	Executing commands and viewing results
Report document	Recording findings and recommendations

5. Theory

5.1 Network Scanning

Network scanning is used to discover reachable hosts and identify network services. Administrators use scan results to review the exposure of their systems and verify that unnecessary services are not accessible.

5.2 Open Ports

A port identifies a communication endpoint associated with a network service. An open port means that a service is accepting connections, but it does not automatically mean the service is vulnerable.

Security teams should determine whether the service is required, appropriately configured, updated, and restricted to authorized clients.

5.3 Service-Version Detection

Service-version detection attempts to identify the software associated with a network service. This information can help administrators determine whether updates or configuration changes are needed.

Version information should be treated as an estimate until confirmed through authorized system administration records.

5.4 Operating-System Detection

Nmap can use network-response characteristics to estimate an operating system. The result may be uncertain or incomplete because of network conditions, firewalls, virtualization, and other factors.

5.5 Nmap Aggressive Scan

The -A option enables multiple detection features. It can provide more information than a basic scan, but it should be used only when the target and scan type are within the approved scope.

6. Procedure

Step 1: Open Kali Linux

Start Kali Linux and open a terminal.

Step 2: Check Nmap installation

Run:

nmap --version

This displays the installed Nmap version.

Screenshot 1: Capture the version output.

Step 3: View the available options

Run:

nmap -h

This displays the command syntax and available scan options.

Screenshot 2: Capture the help output.

Step 4: Select an authorized target

Use a lab virtual machine or another target for which the owner has explicitly approved the intended scan.

Record the target's hostname or IP address in the report. Do not substitute an unrelated public system.

Step 5: Perform a basic scan

Run:

nmap <authorized-lab-host>

Replace <authorized-lab-host> with the approved target hostname or IP address.

This provides a basic view of the target's reachable ports and detected services.

Screenshot 3: Capture the actual scan output.

Step 6: Perform an aggressive scan if authorized

On the same approved lab target, run:

nmap -A <authorized-lab-host>

This requests several detection features, including service/version detection and OS detection. The results depend on the target, network, permissions, and Nmap's ability to identify the services.

Do not use this command against a public target unless the target's current authorization rules explicitly permit this scan type.

Screenshot 4: Capture the aggressive-scan output.

Step 7: Record the findings

Record the detected ports, services, version information, and OS estimate. If the scan does not identify a value, record it as unknown rather than guessing.

Step 8: Assess the security risks

Determine whether each detected service is necessary, whether access is appropriately restricted, and whether the software is maintained and updated.

Step 9: Evaluate social-engineering exposure

Explain at a high level how technical information might make fraudulent IT-support messages seem credible.

Keep the assessment focused on organizational defenses, not on deceiving real employees.

Step 10: Recommend countermeasures

Prepare recommendations for patching, access control, network segmentation, monitoring, employee verification procedures, and information disclosure.

Step 11: Prepare the report

Include the aim, objectives, tools, commands, screenshots, actual findings, risk analysis, countermeasures, and conclusion.

7. Findings Table

Fill in this table using your actual scan output.

Item	Actual finding
Target	Enter the authorized lab hostname/IP
Nmap version	Record the output
Open ports	Record detected ports
Services	Record detected services
Service versions	Record detected versions, if identified
OS estimate	Record the result, including uncertainty
Scan limitations	Record filtered ports, unknown versions, or detection errors

8. Security Risks of Exposed Services

8.1 Unnecessary Open Ports

A service that is exposed without a valid business requirement increases the system's attack surface. Even properly maintained services may create unnecessary risk if they are reachable by untrusted networks.

Recommendation: Disable unnecessary services and restrict required services to approved networks.

8.2 Outdated Service Versions

Older software may lack important security fixes. Identifying the product and version can help an administrator check whether updates are required.

Recommendation: Maintain an asset inventory, apply security updates, and verify the installed versions through authorized administration tools.

8.3 Weak Access Controls

Services that accept connections from broad networks may be exposed to unnecessary access attempts. A service's presence alone does not establish that authentication is weak.

Recommendation: Enforce strong authentication, least privilege, firewall restrictions, and appropriate access logging.

8.4 Inaccurate OS or Version Identification

Nmap detection may produce uncertain or incorrect results. Making security decisions solely on an estimated version can lead to false conclusions.

Recommendation: Confirm important findings using authorized system records and configuration reviews.

8.5 Excessive Technical Information Exposure

Detailed banners and service responses may reveal more information than necessary. This information can help defenders maintain systems, but it can also assist unauthorized parties in understanding the environment.

Recommendation: Minimize unnecessary information disclosure without relying on concealment as the primary security measure.

9. How Technical Information Can Increase Social-Engineering Risk

Social engineering manipulates people into disclosing information or performing unsafe actions. Technical reconnaissance can provide context that makes fraudulent messages appear more believable.

For example, an attacker might use knowledge that an organization operates a particular type of service to make a fake technical-support message sound plausible. A recipient might be more likely to trust a message that appears relevant to their work.

Potential risks include:

1. Fake IT-support requests: Messages pretending to address a technical issue.
2. Impersonation: Messages claiming to come from a trusted internal team.
3. Fraudulent maintenance notices: Messages falsely claiming that a service requires immediate attention.
4. Credential-theft attempts: Messages directing users to an untrusted sign-in page.
5. Unauthorized information requests: Messages asking employees to disclose internal system details.

These examples describe risks at a general level. A scan does not prove that employees will fall for such messages or that a particular system is vulnerable.

10. Defensive Recommendations

1. Minimize exposed services: Disable services that are not required for business operations.
2. Apply security updates: Keep operating systems, applications, and network services supported and patched.
3. Use firewall rules: Permit connections only from required sources and networks.
4. Apply network segmentation: Separate sensitive systems from general user networks.
5. Strengthen authentication: Use multifactor authentication and secure administrative access.
6. Monitor network activity: Review logs for unexpected connections and unusual access patterns.
7. Restrict management interfaces: Keep administrative services away from public or untrusted networks.
8. Reduce unnecessary banners: Avoid exposing detailed software information when it is not needed.
9. Train employees: Teach staff to verify unexpected IT-support requests and report suspicious messages.
10. Verify requests independently: Require a trusted secondary channel for sensitive actions.
11. Maintain an asset inventory: Track service owners, business requirements, versions, and patch status.
12. Repeat authorized assessments: Recheck systems after changes and security updates.

11. Ethical and Legal Considerations

Network scanning must be performed within an explicitly authorized scope. The owner should approve the target, scan type, timing, and testing limits.

Aggressive scans can generate additional network traffic and trigger monitoring alerts. They should not be run against unrelated public systems without explicit authorization for the intended scan.

The purpose of the experiment is to learn how to assess and protect systems, not to gain unauthorized access or deceive real employees.

12. Result

The experiment demonstrates how Nmap can help identify reachable ports, services, and possible operating-system information on an authorized lab target. The scan findings can support a defensive assessment of

unnecessary exposure, patching requirements, access controls, and social-engineering risks. The final report should contain actual scan output and practical security recommendations.